

About Scope



The scope of your evaluation

The root of the English word, 'scope' comes from the Greek word which has the meaning "see". Scope can mean the extent, limit or range of view and in the context of a security certification, means the area that is included in the assessment.

Cyber Essentials is all about cyber security. This involves the protection of your business related information from threats from the internet. Almost every business these days uses internet connected devices such as smart phones and computers and digital services such as email, websites and e-commerce. The scope of the Cyber Essentials assessment includes the IT infrastructure used to perform your business. This will include all devices that access your business data such as work emails, customer data, website and online services and the information you access in the cloud (remotely). The focus of Cyber Essential is to protect your business, your devices and your data from the most common cyber attacks.

Cyber Essentials is suitable for businesses of all sizes

Consider your organisation and what kind of technology it includes. If you are a consultant, it might be just you working from home, with your phone and computer and some cloud services such as Microsoft 365. If you are a builder or a mobile hairdresser, it might be just you working from your customer's home with your mobile phone. Perhaps your work spans across multiple locations? Do you have a physical office or shop as well as an online presence? Do you have staff who work from home or want to use their own equipment for work? Can all of your organisation have the Cyber Essentials controls applied to it?

One of the first things you must do when applying for Cyber Essentials, is establish the boundary of scope for your organisation and determine what is in scope within this boundary. This means clarifying exactly what is included in your certification.

Certifying your whole organisation

Ideally, the scope of your Cyber Essentials certification will be "whole organisation" because this gives you the most protection. It will also mean that you qualify for the included cyber liability insurance (if your annual turnover is less than £20 million and you are domiciled in the UK).

Certifying only part of your organisation

Technically separating part of your IT infrastructure by creating a sub-set

In some cases, however, it is not possible to have the whole organisation in scope, for example, if you want to use devices or software that do not meet the Cyber Essentials requirements because they are no longer supported by the manufacturer. In this case, you must have a way to technically separate what is in scope from what is not. This can be achieved by creating a **subset** using a **VLAN** or **firewall**, which controls access to the parts of the network that are included in the assessment in order to segregate and protect it from any **vulnerabilities** that occur from within the network that is out of scope. When you can not certify your whole organisation, you must be able to clearly describe what is included in the scope (eg, whole organisation excluding the development network). Please note, it is not unusual to need some professional help to achieve this (see **help and support** below).

If your organisation has a segregated 'guest' network that does not interact with other organisational data or services and allows people outside of the organisation to use the internet, this can be excluded from the scope. An example would be a hotel with a guest network or a student network in a school. This is an exception to the rule and the certification scope can still be described as 'whole organisation'.

Boundary of scope

For the purposes of Cyber Essentials, the boundary of scope is the **firewalls** and **routers** which are creating the first line of defence between your networks and devices and the internet. The control requirements in section 1 -Firewalls, would need to be applied to these firewalls and routers.

IT equipment that does not connect to the internet

If you have IT equipment that does not ever connect to the internet or connect to an internet-connected network, then you do not need to declare it.

Home working

Anyone working from home for any amount of time, is classified as a 'home worker'. The devices that home workers use for business purposes are in scope for Cyber Essentials. This includes personal mobile phones that are used to access work emails.

All devices that access **organisational data or services** are in scope and this will include those used by employees, volunteers, trustees, school governors and contractors.

What is organisational data?

Any electronic data belonging to the organisation. e.g. emails, office documents, database data, financial data.

What is organisational services?

Any **software applications** (apps), **cloud applications**, cloud services, **virtual desktops** and **mobile device management solutions** owned or subscribed to by the organisation. e.g **web applications**, MS 365, Google Workspace, MDM Containers, Citrix Desktop, VDI solutions, RDP desktop.

All cloud services

All **cloud services** are in scope and need to meet the Cyber Essentials controls. If your organisation's data or services are hosted in the cloud, then your organisation is responsible for ensuring that all the Cyber Essentials controls are implemented within those services.

Whether the cloud service provider or your organisation implements the control, depends on the type of cloud service, but you have the responsibility to ensure the appropriate controls are in place for all cloud services.

Must include end point devices

The scope of an organisation certifying to Cyber Essentials must include end point devices (e.g pcs, laptops, tablets and mobile devices that have interfaces used by people).

If an organisation certifies their **server** systems only, they ignore the potential threats that come from their administrators who administered those server systems. This specification closes the loop-hole where organisations used to be able to certify their company without including any end user devices.

Help and support

If you have a complex company structure and believe the assessment would not cover the whole of your organisation, you may need to seek professional advice on how you would apply controls to a subset of your organisation to allow part of it to be in scope for Cyber Essentials.

There are over 300 specially trained cyber security companies around the UK who are licensed to certify against the Government's Cyber Essentials Scheme. They can offer help and support in preparation for the assessment. [Find one near you.](#)

For questions and feedback about the Cyber Essentials scheme, contact IASME at info@iasme.co.uk or Tel: 03300 882 752